AEGISAI ENTERPRISE EDITION

SUITE DE DOCUMENTACIÓN TÉCNICA

Manual de Uso del Operador y Auditor

Guía Operativa para Evaluación y Verificación de Arquitecturas de IA

Versión de Plataforma:	**2.5.0 Enterprise Edition**
Alcance Normativo:	**OWASP AISVS v1.0, ISO/IEC 42001:2023, Google Cloud Security**
Licencia:	**Apache License 2.0 (Open Source)**

AEGIS AI ASSURANCE PLATFORM

Manual de Usuario Final y Guía Operativa Oficial

Versión de la Plataforma: 2.5.0 Enterprise (Edición 2026)

Clasificación: Documentación Oficial para Usuarios y Oficiales de Cumplimiento

Estándares Cubiertos: OWASP AI-SVS 1.0, ISO/IEC 42001:2023, Bring Your Own Framework (BYOF: LFPDPPP, LFPC, EU AI Act)

---

1. Introducción y Visión General

1.1 ¿Qué es AegisAI?

AegisAI es una plataforma empresarial diseñada para automatizar la auditoría de seguridad, el análisis de riesgos algorítmicos y la certificación de cumplimiento normativo en aplicaciones basadas en Inteligencia Artificial y Modelos de Lenguaje Grande (LLMs).

AegisAI evalúa la arquitectura técnica, los componentes de Recuperación Aumentada por Generación (RAG), los almacenes vectoriales, los agentes autónomos y la infraestructura subyacente frente a los marcos internacionales y leyes territoriales más estrictos del mundo.

1.2 Principios Rectores de AegisAI

La plataforma opera bajo cuatro principios inmutables de aseguramiento:

1. **Inferencia Hiper-Factual Determinista:** Las evaluaciones se ejecutan con parámetros estrictos (`temperature: 0.0` , `topK: 1` , `topP: 0.0`), eliminando cualquier alucinación en los dictámenes de cumplimiento.
2. **Evidencia Textual Obligatoria:** Ningún control puede calificarse como "Aprobado" si no existe una cita textual explícita extraída de la documentación del sistema. En su ausencia, el sistema emite "Falta Evidencia".
3. **Modelo de Responsabilidad Compartida en IA:** Cuando la arquitectura auditada corre sobre servicios totalmente gestionados como **Google Gemini Enterprise SaaS**, la plataforma acredita automáticamente las salvaguardas que el proveedor garantiza contractualmente (Zero Data Retention, blindaje físico de pesos fundacionales, certificaciones ISO 27001/42001/SOC 2).
4. **Inmutabilidad de Registros (Invariante 4 OWASP AISVS):** Una vez concluida una auditoría, su reporte y puntuaciones son inalterables y quedan resguardados criptográficamente para auditorías forenses y regulatorias.

---

2. Mapa de Navegación del Sistema

La interfaz de usuario de AegisAI consta de una barra lateral de acceso rápido con las siguientes vistas principales:

Módulo	Icono	Propósito Operativo
Dashboard	📊	Panel ejecutivo con KPIs de postura, métricas por estándar, tasa de aprobación y listado histórico de auditorías inmutables.
Nueva Auditoría	🛡️	Formulario interactivo en 4 secciones para parametrizar la arquitectura y lanzar la evaluación.
Catálogo de Estándares	📚	Biblioteca interactiva con los 12 capítulos de OWASP AI-SVS 1.0, los 10 dominios de ISO 42001 y las leyes del módulo BYOF.
Arquitectura del Sistema	🏗️	Visor de la topología de seguridad, microservicios y flujo de datos de referencia de AegisAI.
Configuración y Admin	⚙️	Panel de administración de tokens, claves de API de Gemini, telemetría y pruebas de conectividad.

3. Marcos Normativos y Leyes Soportadas

AegisAI permite auditar sistemas bajo 4 modalidades normativas:

3.1 OWASP Artificial Intelligence Security Verification Standard (AISVS 1.0)

Diseñado específicamente para ciberseguridad técnica en IA. Consta de 12 capítulos canónicos:

- `C01` : Integridad y Trazabilidad de Datos de Entrenamiento.
- `C02` : Validación de Entradas y Defensa ante Inyecciones (Prompt Injections).
- `C03` : Gestión del Ciclo de Vida del Modelo y Versionado Criptográfico.
- `C04` : Seguridad de Infraestructura y Aislamiento en Contenedores / MicroVMs.
- `C05` : Control de Acceso, Identidad y Gestión de DEKs.
- `C06` : Seguridad en la Cadena de Suministro (AIBOM y escaneo SCA).
- `C07` : Comportamiento del Modelo y Manejo Seguro de Salidas (Anti-XSS).
- `C08` : Memoria, Embeddings y Bases de Datos Vectoriales (ACLs en RAG).
- `C09` : Orquestación Agéntica, Tools y Human-in-the-Loop.
- `C10` : Seguridad del Model Context Protocol (MCP) y TLS 1.3.
- `C11` : Robustez Adversarial y Prevención de Denegación de Billetera (DoW).
- `C12` : Monitoreo Continuo, Auditoría y Trazabilidad WORM / SIEM.

3.2 ISO/IEC 42001:2023 (Artificial Intelligence Management System - AIMS)

Estándar internacional para la gobernanza corporativa, gestión de riesgos éticos y ciclo de vida de IA en las organizaciones (10 dominios y 38 controles del Anexo A).

3.3 Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP - México / INAI)

Marco legal obligatorio en México para el tratamiento de datos de usuarios en sistemas de IA:

- Principios de licitud, lealtad y minimización en prompts (`CAP-01`).
- Aviso de privacidad integral y consentimiento expreso para datos biométricos (`CAP-02`).
- Cifrado de bases vectoriales RAG y redacción de PII con DLP (`CAP-03`).
- Ejercicio efectivo de Derechos ARCO y purga de vectores para el derecho al olvido (`CAP-04`).

- Transferencias internacionales a nubes con garantía Zero Data Retention (`CAP-05`).
- Detección de exfiltraciones de datos por inyección de prompts (`CAP-06`).

3.4 Ley Federal de Protección al Consumidor (LFPC - México / PROFECO)

Marco legal obligatorio en México para chatbots de atención a clientes, cotizadores y e-commerce:

- Identificación obligatoria de que el usuario habla con un bot de IA (`CAP-01`).
- Factual grounding en precios y carácter vinculante de ofertas informadas (`CAP-02`).
- Resumen previo de compra y derecho legal de retracto en 5 días hábiles (`CAP-03`).
- Prohibición de precios discriminatorios por perfilamiento algorítmico (`CAP-04`).
- Escalamiento irrestricto a agentes humanos y folios para quejas ante PROFECO (`CAP-05`).
- Aislamiento PCI-DSS de medios de pago y reversión de cargos no autorizados (`CAP-06`).

3.5 Ley de Inteligencia Artificial de la Unión Europea (EU AI Act)

Reglamento (UE) 2024/1689 para sistemas de IA de alto riesgo (gestión de riesgos, datos de entrenamiento, transparencia y ciberseguridad).

---

4. Guía Paso a Paso: Cómo Realizar una Auditoría

Paso 1: Iniciar la Evaluación

1. Diríjase a la barra lateral y haga clic en "**Nueva Auditoría**" o pulse el botón "**+ Nueva Auditoría**" en el Dashboard.
2. Accederá al formulario interactivo dividido en 4 secciones secuenciales.

Paso 2: Configurar la Sección 1 - Selección de Normativas (Auditoría Simultánea)

AegisAI permite seleccionar uno o múltiples marcos normativos para evaluarlos de forma concurrente en una sola ejecución:

- **Tarjetas Multi-Selección:** Marque las casillas correspondientes a las normas requeridas (OWASP AI-SVS 1.0, ISO/IEC 42001:2023, LFPDPPP México, LFPC México, EU AI Act o marcos personalizados).
- **Accesos Rápidos de un Clic:**
- 🌟 **Auditoría Integral 360° (4 Normas):** Evalúa conjuntamente AISVS + ISO 42001 + LFPDPPP + LFPC en una sola corrida.
- 🇲🇽 **Leyes Mexicanas:** Evalúa conjuntamente LFPDPPP (Privacidad / INAI) y LFPC (Consumidor / PROFECO).
- 🛡️ **Técnico Dual:** Evalúa conjuntamente OWASP AISVS (Seguridad Técnica) e ISO 42001 (Gobernanza SGIA).
- **Individuales:** Seleccione únicamente la norma deseada si busca una auditoría puntual.
- **Resumen Dinámico:** Un banner inferior lista todas las normas activas y habilita la remoción rápida con un clic.

Paso 3: Configurar la Sección 2 - Nivel de Verificación OWASP AI-SVS

- **Auto-detectar por IA (Recomendado):** Analiza el riesgo del sistema y asigna el nivel automáticamente conforme al EU AI Act y OWASP AISVS.
- **Nivel 1 (L1 - Esencial):** Para aplicaciones de productividad básica.
- **Nivel 2 (L2 - Estándar):** Para sistemas con PII, bases RAG corporativas o soporte al cliente.
- **Nivel 3 (L3 - Crítico):** Para sistemas financieros, médicos o agentes autónomos transaccionales.

Paso 4: Configurar la Sección 3 - Datos del Sistema y Arquitectura

- **Nombre del Sistema:** Nombre oficial de la aplicación (ej. *BancaMovil AI*).
- **Líder Técnico y Correo:** Responsable técnico del sistema para la matriz RACI.
- **Documentación Técnica:** Adjunte especificaciones en formato `.pdf`, `.txt` o `.md`, o pegue el texto de la arquitectura en el cuadro de texto. Puede ingresar especificaciones de más de 50 páginas (hasta 1,000,000 de caracteres).

Paso 5: Configurar la Sección 4 - Plataforma y Responsabilidad Compartida

Indique la infraestructura sobre la que corre su sistema:

- **Google Gemini Enterprise (SaaS):** Acredita automáticamente las garantías de Google Cloud (Zero Data Retention, microVMs, certificaciones ISO 27001/42001/SOC 2).
- **Google Cloud Vertex AI (PaaS):** Acredita aislamiento de endpoints, CMEK y VPC-SC.
- **Azure OpenAI / AWS Bedrock:** Perfiles PaaS correspondientes.
- **Auto-hospedado (Open-Weights):** Exige al usuario demostrar el 100% de la infraestructura y firma de pesos.
- **Auto-detectar con IA:** El motor analiza la documentación y selecciona el perfil idóneo.

Paso 6: Lanzar y Monitorear la Auditoría

1. Haga clic en **"Ejecutar Auditoría Multi-Normativa"** (el botón refleja dinámicamente el número de normas seleccionadas).
2. Observe el avance en vivo mediante la consola de streaming Server-Sent Events (SSE). El pipeline Map-Reduce procesará los lotes secuencialmente transmitiendo la etapa activa y el porcentaje.
3. Al finalizar, será redirigido automáticamente a la vista de resultados de **Compliance 360°**.

4.1 Auditoría en Vivo de Proyectos Google Cloud (GCP Live Scanner - Zero-Footprint)

Si su organización opera cargas de trabajo de IA en **Google Cloud**, AegisAI le permite auditar la infraestructura viva directamente conectándose a las APIs oficiales de administración (Cloud Control Plane), sin necesidad de redactar documentos ni subir archivos manualmente.

A. Garantía de Cero Huella (Zero-Footprint Invariant)

- **Cero Recursos Creados:** No se instala ningún software, agente, Cloud Function, máquina virtual ni bucket en el proyecto del cliente.
- **Peticiones Estrictamente de Solo Lectura:** El módulo solo realiza llamadas `HTTP GET` de consulta de metadata. Ningún recurso ni permiso IAM es modificado.

B. Pasos para Auditar un Proyecto en Vivo

1. En la barra lateral, haga clic en la opción **"Auditar Google Cloud"** (icono de nube).
2. **Seleccione el Método de Autenticación:**
   - **Demo / Simulación:** Carga un stack empresarial preconfigurado (`aegis-fintech-ai-prod`) con Vertex AI, Cloud Run, Cloud Storage e IAM para pruebas inmediatas sin credenciales.
   - **ADC / Cloud Run:** Conexión automática nativa si AegisAI corre en Cloud Run o en un entorno con Application Default Credentials activos.
   - **Token Temporal:** Ingrese un token de acceso generado con `gcloud auth print-access-token`.
   - **Cuenta de Servicio:** Pegue el JSON de una cuenta de servicio con rol de lectura; la autenticación se firma en memoria volátil sin persistir el archivo.

3. **Especifique el Project ID:** Ingrese el ID del proyecto a auditar y presione **"Probar Conexión"** para validar permisos.
4. **Seleccione los Componentes a Inspeccionar:** Active las casillas de Vertex AI, Cloud Run, Cloud Storage, IAM y Secret Manager/KMS.
5. **Elija las Normas de Cumplimiento:** Seleccione los marcos deseados (ej. preset ⚡ 360° o 🇲🇽 Leyes Mexicanas).
6. **Pulse "Escanear y Auditar":**
   - El escáner recolectará la telemetría en tiempo real y emitirá el inventario de activos descubiertos.
   - El motor de IA evaluará la infraestructura real y generará el reporte con citas a los recursos específicos (ej. `gs://bucket-transcripts`, `endpoints/12345`).

---

5. Módulo BYOF: Ingestión de Nuevas Leyes o Políticas

AegisAI permite que cualquier organización audite sistemas contra sus propias políticas internas o regulaciones locales sin escribir código:

1. Vaya a **"Catálogo de Estándares"** > Pestaña **"Leyes y Políticas (BYOF)"**.
2. Haga clic en el botón superior **"+ Ingestar Nueva Ley o Política"**.
3. En el modal emergente, elija si desea subir un archivo (PDF, DOCX, TXT, MD) o pegar el texto de la ley/política.
4. Escriba el nombre de la regulación (ej. *Circular Única de Bancos CNBV*) y la jurisdicción.
5. Pulse **"Iniciar Ingesta Normativa"**.
6. En aproximadamente 570 milisegundos, el modelo Gemini Flash-Lite descompondrá la ley en capítulos y controles con identificadores atómicos, criterios de prueba y recetas de mitigación.
7. Haga clic en **"Auditar con este Marco"** para evaluar cualquier sistema contra la nueva ley de inmediato o selecciónela en conjunto con otras normas en el formulario principal.

---

6. Interpretación del Reporte Técnico y Planes de Acción

6.1 Estructura del Reporte

- **Encabezado y Badge 360°:** Muestra el ID único, fecha, plataforma tecnológica y si corresponde a una auditoría individual o **Multi-Normativa 360°**.
- **Panel de Cuadro de Mando Multi-Normativo (Compliance 360°):** Cuando se evalúan múltiples normas simultáneamente, despliega una matriz de tarjetas con la puntuación independiente de cada norma (0-100%), barra de avance visual, proporción de controles aprobados y botón rápido de filtrado.
- **Pestañas de Filtrado por Norma:** En la barra lateral izquierda, permite filtrar los capítulos para ver "Todas" o aislar únicamente los capítulos de "OWASP AISVS", "ISO 42001", "LFPDPPP", "LFPC", etc.
- **Banner de Responsabilidad Compartida:** Detalla los controles acreditados por herencia formal de la nube.
- **Pestañas de Filtrado por Alcance:** Permiten visualizar "Todos los Controles", "Mandatorios L1-L3", "Recomendaciones Superiores" o "Heredados de Plataforma".

6.2 Estados Normativos de los Controles

- **Aprobado (Verde):** El documento demuestra satisfactoriamente la implementación del requisito.
- **Aprobado [Heredado] (Verde con badge azul):** El requisito está cubierto por el contrato de servicio en la nube (SaaS/PaaS).
- **Requiere Revisión (Ámbar):** El control existe pero carece de robustez técnica (puntuación parcial).

- **Falta Evidencia (Rojo):** La documentación no menciona el requisito obligatorio (0% en el control).
- **No Aplica (Gris):** El componente no forma parte del sistema.

6.3 Recetas de Mitigación Cuatridimensionales (4D)

Cada hallazgo no conforme contiene una pestaña desplegable con:

1. **Estrategia:** Principio arquitectónico de defensa aplicable.
2. **Pasos Accionables:** Tareas concretas y secuenciales para el equipo de desarrollo.
3. **Código o Configuración:** Manifiestos de Kubernetes, Docker, TypeScript o Python listos para producción.
4. **Receta QA / Pentesting:** Comandos de `curl` o scripts de prueba automatizada para verificar el cierre de la brecha.
5. **Esfuerzo y Herramientas:** Tiempo estimado (*Quick Win < 1 día, Medio 1-3 días, Estructural > 1 semana*) y herramientas recomendadas (*Microsoft Presidio, Sigstore, gVisor*).

6.4 Telemetría del Motor de Inferencia en el Reporte

En la cabecera del reporte de auditoría se presenta una tarjeta de telemetría en tiempo real:

- **Modelo de IA Utilizado:** Muestra el modelo exacto que resolvió la auditoría (ej. `gemini-3.8-flash`, `anthropic/claude-3.7-sonnet`, `gpt-4o`).
- **Latencia de Inferencia:** Tiempo total en milisegundos que tomó la evaluación.
- **Consumo de Tokens:** Conteo auditado de tokens de entrada (`promptTokens`) y tokens generados (`completionTokens`).

6.5 Descarga de Arquitectura Remediada (100% de Cumplimiento)

Si la auditoría presenta áreas de oportunidad o controles en estado `Fallido` o `Falta Evidencia`, la plataforma habilita automáticamente el panel de **Correcciones Sugeridas**:

1. **Acceso Rápido:** Haga clic en el botón **"Correcciones Sugeridas (.md)"** en la barra superior del reporte o en el panel destacado esmeralda.
2. **Modal de Vista Previa:** Permite explorar interactivamente la arquitectura completa corregida, con syntax highlighting y botón para **Copiar al Portapapeles**.
3. **Descarga de Especificación (.md / .txt):** Descarga el archivo de reemplazo directo (*Drop-in Replacement*) que integra la arquitectura original junto con todas las salvaguardas (sanitización anti-inyección, anonimización DLP, RAG por inquilino, logs WORM y escalamiento humano).
4. **Re-auditar:** Permite cargar automáticamente el documento corregido en una nueva auditoría para certificar la obtención del **100.0% de cumplimiento**.

6.6 Exportación Formal

- **Exportar Markdown (.md):** Descarga el plan de acción estructurado con matriz RACI, ideal para sincronizar con Jira o Confluence.
- **Exportar PDF Oficial:** Descarga el documento corporativo de alta calidad con tabla de firmas formales para aprobación del CISO.

---

7. Preguntas Frecuentes (FAQ)

P: ¿Por qué no puedo eliminar una auditoría realizada en el pasado?

R: Por exigencia estricta del **Invariante 4 de OWASP AI-SVS** y las normas ISO de aseguramiento, las auditorías son legalmente inmutables para impedir el borrado de evidencias en investigaciones de seguridad o fraudes de cumplimiento.

P: ¿Qué ocurre si mi documento de arquitectura excede las 50 páginas?

R: AegisAI cuenta con una arquitectura Map-Reduce con ventana de entrada de hasta 1 millón de caracteres. Puede ingresar el documento completo sin temor a truncamientos.

P: ¿Cómo sé qué controles cubre Google Cloud en Gemini Enterprise?

R: En el reporte de auditoría, haga clic en la pestaña "Heredados de Plataforma". Allí verá los controles de protección de pesos fundacionales, microVMs y Zero Data Retention formalmente acreditados con cita de certificaciones ISO 27001, ISO 42001 y SOC 2.